ANALYSE STATIQUE DE MALWARE

Fichier satan.bin — Ransomware

Année 2024-2025

-Ilyes Sadadou-

1. Introduction — Qu'est-ce que l'analyse statique ?

Avant de plonger dans l'analyse du fichier satan.bin, il est essentiel de comprendre ce qu'est une analyse statique et pourquoi elle est fondamentale en cybersécurité.

> **Définition — Analyse statique**
> L'analyse statique consiste à examiner un fichier malveillant SANS l'exécuter. On inspecte sa structure, ses métadonnées, son code et ses chaînes de caractères avec des outils spécialisés.
>
> Avantages : sécurité totale (pas de risque d'infection), rapide, reproductible.
> Limites : ne révèle pas le comportement réel à l'exécution (certains malwares se déchiffrent à la volée).

1.1 Outils utilisés dans cette analyse

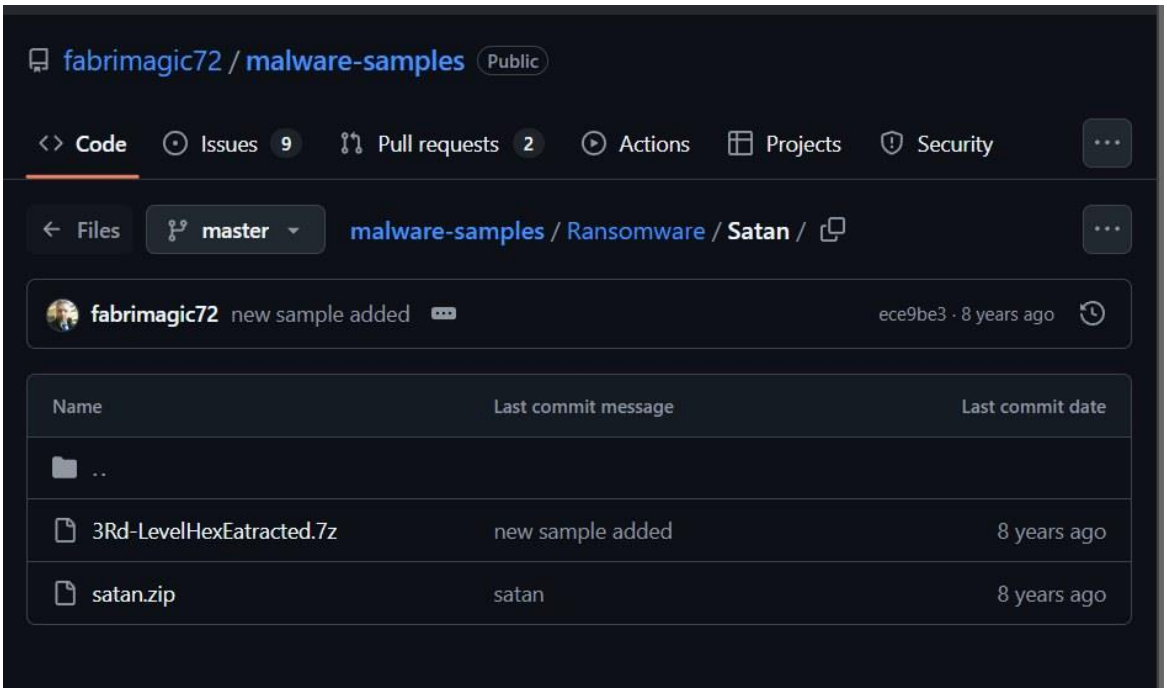
Quatre outils ont été mobilisés, chacun apportant un niveau d'information différent :

Outil	Rôle	Ce qu'il révèle
HxD / hexed.it	Éditeur hexadécimal	Signature magique, structure brute des octets
Exeinfo PE	Identifier la structure PE	Point d'entrée, sections, overlay, packer
PE Studio	Analyse statique avancée	Imports, strings, entropie, score de menace
VirusTotal	Agrégateur d'antivirus	Détection multi-moteurs, classification famille

2. Préparation de l'Environnement

2.1 Récupération du fichier — Dépôt GitHub

Le fichier satan.bin a été récupéré depuis un dépôt public GitHub dédié aux échantillons de malwares à des fins de recherche et d'enseignement : *github.com/fabrimagic72/malware-samples*. Ce dépôt est utilisé par des chercheurs en cybersécurité du monde entier. Il y a aussi le site MalwareBazaar qui est pas mal.



▲Dépôt GitHub malware-samples — dossier Ransomware/Satan

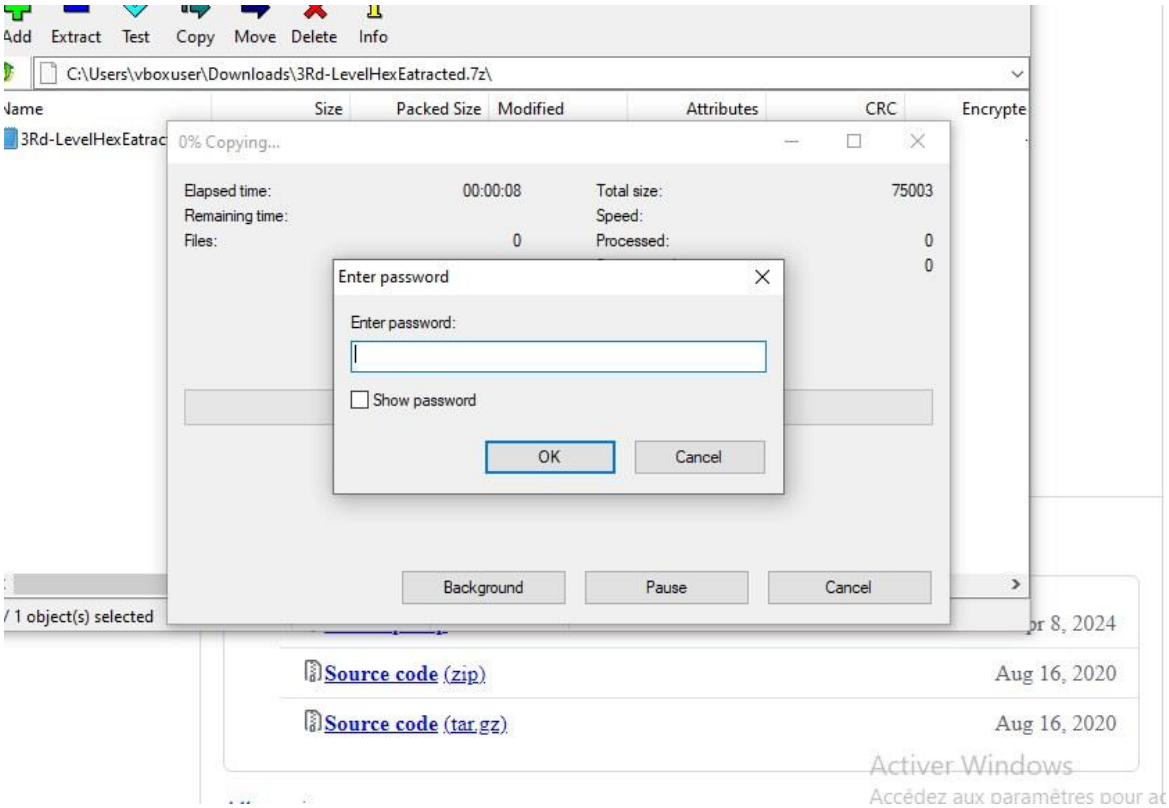
Pourquoi un dépôt public de malwares ?

Des chercheurs en sécurité maintiennent des dépôts publics d'échantillons malveillants pour permettre à la communauté d'étudier les menaces réelles sans les propager.

Ces archives sont TOUJOURS protégées par un mot de passe standard (ici : 'infected') pour éviter une extraction accidentelle.

2.2 Extraction protégée par mot de passe

Les archives malveillantes sont systématiquement compressées et protégées par un mot de passe afin d'éviter que les antivirus ne les détectent ou ne les suppriment automatiquement lors du téléchargement.



▲*Extraction de l'archive 7z avec demande de mot de passe ('infected')*

7z2409-x64.exe	1 637 343	2025-01-09 10:30	2025-01-09 10:30
desktop.ini	282	2025-01-09 10:25	2025-01-09 10:25
exeinfope.zip	2 148 218	2025-01-09 10:54	2025-01-09 10:54
pestudio.zip	1 138 430	2025-01-09 10:55	2025-01-09 10:55
satan.bin	189 337	2017-05-20 14:22	2017-05-20 14:22
satan.zip	146 558	2025-01-09 10:40	2025-01-09 10:40

▲*Fichiers extraits : on voit satan.bin (189 337 octets, daté 2017)*

À retenir

Le fichier satan.bin pèse 189 337 octets (≈ 185 Ko). Sa date de création est le 20 mai 2017. L'extension .bin est volontairement neutre pour tromper l'utilisateur ce fichier est en réalité un exécutable Windows PE.

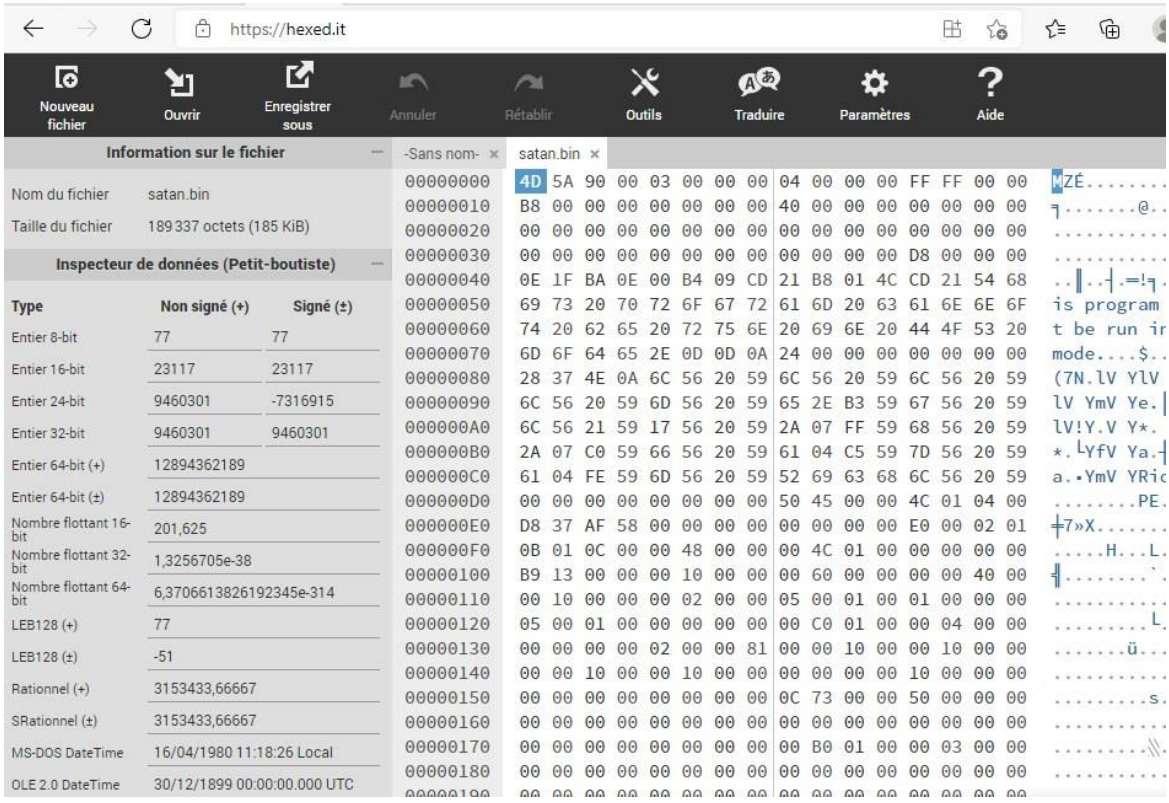
3. Analyse Hexadécimale — HxD

3.1 Qu'est-ce qu'un éditeur hexadécimal ?

Un éditeur hexadécimal affiche le contenu brut d'un fichier octet par octet, en notation hexadécimale (base 16). C'est la forme la plus fondamentale d'inspection d'un fichier : on voit exactement ce qu'il contient, sans interprétation.

> **Rappel — Hexadécimal**
> Un octet peut avoir 256 valeurs (0 à 255). En hexadécimal, on les représente avec 2 chiffres de 0 à F.
> Exemples : 0x4D = 77 en décimal = 'M' en ASCII | 0x5A = 90 = 'Z' en ASCII
> Les deux premiers octets d'un fichier s'appellent la 'signature magique' ou 'magic number'.

3.2 La signature MZ — Preuve d'un exécutable Windows



▲*HxD — Les deux premiers octets sont 4D 5A ('MZ') : signature d'un fichier PE Windows*

La première chose que l'on remarque à l'offset 0x00000000 est la séquence : 4D 5A. Ces deux octets forment la signature universelle des fichiers Portable Executable (PE) sous Windows.

4D 5A = 'MZ' en ASCII = Magic Number des fichiers exécutables Windows (format PE).
Le fichier est renommé en .bin mais c'est bel et bien un programme Windows
Cette technique de camouflage est très courante dans les malwares pour tromper les utilisateurs novices.

3.3 La chaîne DOS Stub

Plus loin dans le fichier, on retrouve la chaîne de caractères lisible en clair :

```
This program cannot be run in DOS mode
```

Explication pédagogique

Tous les fichiers PE modernes contiennent ce message dans leur en-tête DOS. Il s'affiche si quelqu'un tente d'exécuter le fichier sous MS-DOS (obsolète).
Sa présence confirme que le fichier respecte le format PE standard — il n'est pas corrompu.
On voit aussi que l'entropie est de 7.072 (proche de 8 = maximum) → le contenu est fortement compressé ou chiffré.

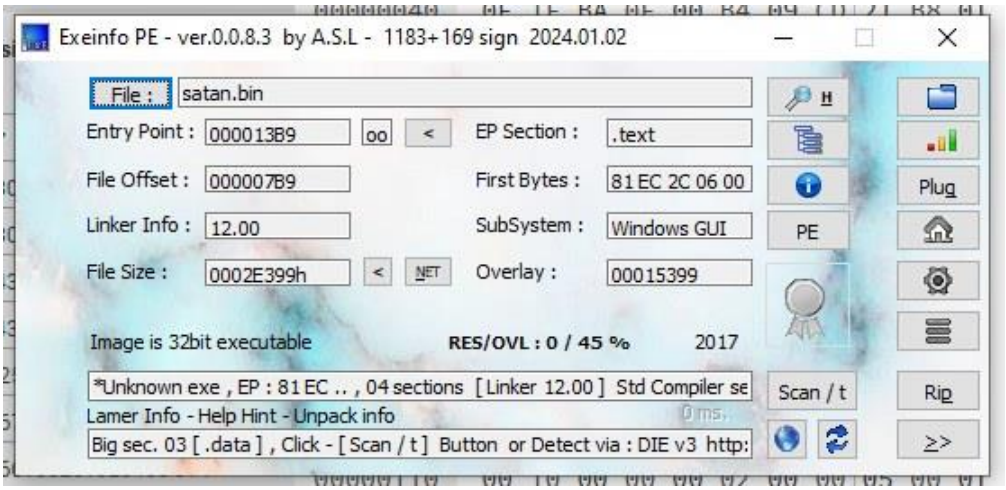
4. Structure du Fichier PE — Exeinfo PE

4.1 Qu'est-ce que le format PE ?

PE (Portable Executable) est le format standard des fichiers exécutables sous Windows (.exe, .dll, .sys...). Ce format contient des métadonnées précises : où commence le code, quelles bibliothèques il utilise, comment il s'organise en mémoire.

> **Structure d'un fichier PE (résumé)**
> 1. En-tête DOS (64 octets) : compatibilité DOS, contient le saut vers l'en-tête PE.
> 2. En-tête PE (signature 'PE\0\0' + COFF Header) : type de CPU, nombre de sections.
> 3. Optional Header : point d'entrée, sous-système, taille d'image.
> 4. Section Table : liste des sections (.text, .data, .rdata, etc.)
> 5. Sections : le contenu réel (code, données, ressources).
> 6. Overlay (optionnel) : données ajoutées APRÈS la fin du PE standard → souvent suspect.

4.2 Résultats d'Exeinfo PE



▲*Exeinfo PE — Analyse complète de la structure de satan.bin*

Exeinfo PE nous donne une radiographie précise du fichier. Décortiquons chaque champ :

Champ	Valeur	Interprétation pédagogique
Entry Point	0x00001389	Adresse en mémoire virtuelle où démarre l'exécution. Situé dans .text → normal.
File Offset	0x000007B9	Position physique dans le fichier. Permet de désassembler directement les premières instructions.
EP Section	.text	Section de code exécutable. Un EP dans .text est attendu pour un programme normal.

Champ	Valeur	Interprétation pédagogique
Linker Info	12.00	Version de l'éditeur de liens (Visual Studio 2013). Indique l'environnement de compilation.
File Size	0x0002E399h	189 337 octets. Cohérent avec ce qu'on a vu dans l'explorateur.
Overlay	0x00015399	Données APRÈS la fin du PE standard. Taille significative → TRÈS SUSPECT.
First Bytes	81 EC 2C 06 00	SUB ESP, 62C → ajustement de pile. Prologue typique d'une fonction C/C++ compilée.
Subsystem	Windows GUI	Interface graphique Windows. Le malware peut afficher une fausse fenêtre pour tromper.
32-bit	Oui	Exécutable 32 bits → compatible avec tous les Windows (x86 et x64).
RES/OVL	0 / 45%	L'overlay représente 45% du fichier total → contient probablement la charge utile chiffrée.

Point critique — L'Overlay

Un overlay de 45% du fichier est un signal d'alarme fort. Les ransomwares utilisent fréquemment cette zone pour y stocker :

→ La charge utile chiffrée (payload) qui sera déchiffrée et exécutée en mémoire.

→ Les clés de chiffrement ou la configuration du malware.

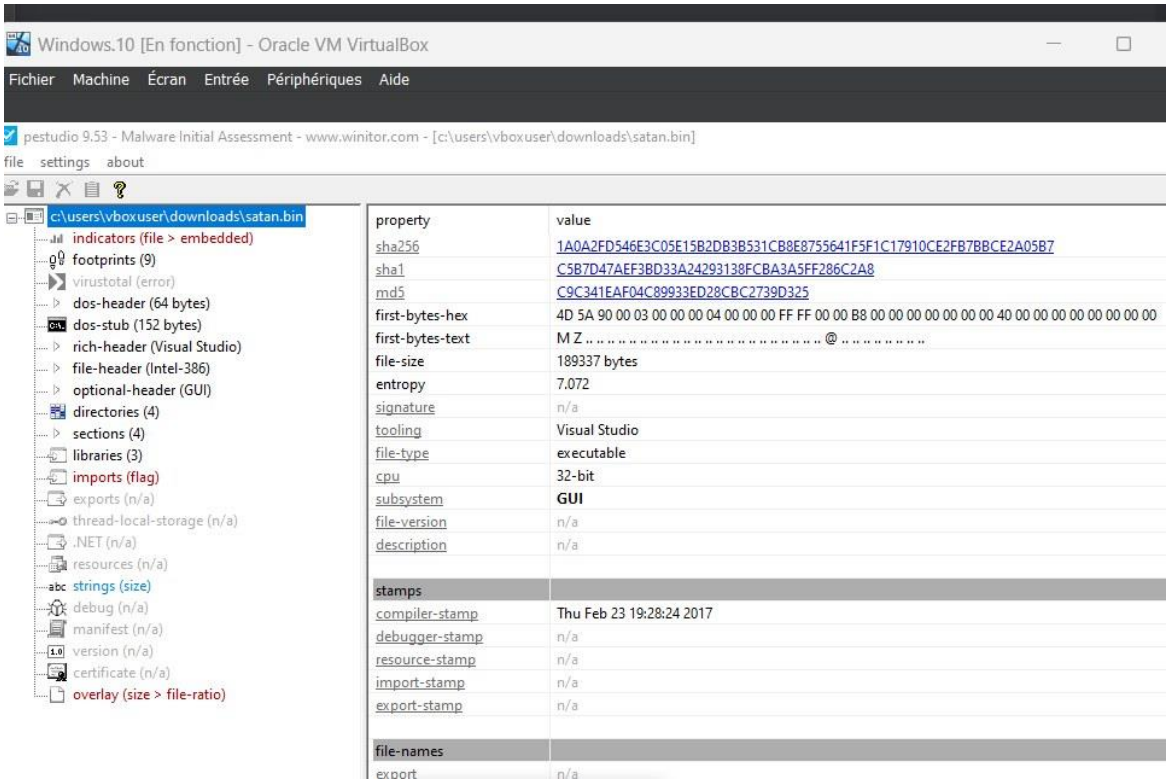
→ Un second exécutable embarqué (dropper).

Exeinfo PE nous indique aussi : Big sec. 03 [.data] → la section .data est anormalement grande, même constat.

5. Analyse Approfondie — PE Studio

5.1 Vue générale et indicateurs

PE Studio est l'outil de référence pour l'analyse statique avancée des fichiers PE. Il calcule automatiquement les hashes, mesure l'entropie, analyse les imports et les chaînes de caractères, et fournit un score de menace.



▲PE Studio — Vue générale : hashes, entropie 7.072, compilation Feb 2017, subsystem GUI

Les hashes cryptographiques

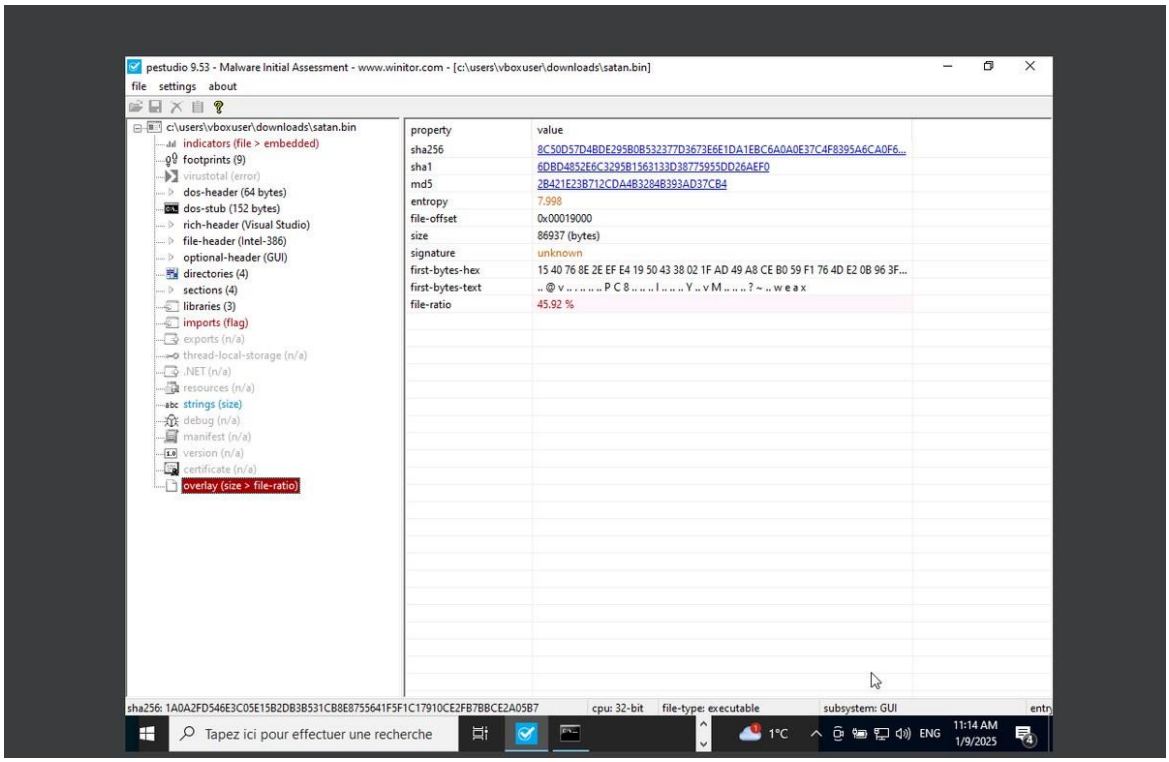
PE Studio calcule automatiquement trois empreintes du fichier :

Hash	Valeur	Usage
SHA256	1A0A2FD5...CE2A05B7	Identifiant unique du fichier. Référence mondiale pour la recherche de menaces.
SHA1	C5B7D47A...286C2A8	Hash plus ancien, encore utilisé par certaines bases de données.
MD5	C9C341EA...2739D325	Hash rapide, non cryptographiquement sûr mais toujours utilisé comme référence.

Pourquoi les hashes sont-ils importants ?

Un hash est une empreinte digitale numérique. Si UN SEUL octet du fichier change, le hash est complètement différent.
Les bases de données comme VirusTotal, MalwareBazaar ou AlienVault OTX permettent de rechercher un fichier par son hash SHA256.
Le SHA256 de satan.bin est connu et référencé comme malveillant depuis 2017.

5.2 L'Overlay et l'entropie — Signaux d'alarme



▲PE Studio — L'overlay est mis en évidence en rouge : taille > ratio fichier (45.92%)

L'entropie en cybersécurité

L'entropie mesure le degré de 'désordre' ou d'aléatoire d'une séquence d'octets (Shannon entropy, 0 à 8).
0 = tous les octets identiques (ex: fichier rempli de zéros).
8 = parfaitement aléatoire indique du contenu CHIFFRÉ ou COMPRESSÉ.
satan.bin affiche une entropie de 7.072 et 7.998 pour l'overlay → fortement chiffré.
Valeur normale d'un .exe non chiffré est entre 4.5 et 6.5.

Analyse de l'overlay

File-offset : 0x00019000 → l'overlay commence à l'adresse 0x19000 dans le fichier.
Taille : 86 937 octets.
Entropie : 7.998 → quasi-maximum → contenu chiffré ou une clé de chiffrement.
Signature : 'unknown' → aucun format reconnu (contrairement à .zip, .pdf, etc.).
Conclusion : cet overlay contient très probablement la charge utile chiffrée du ransomware.

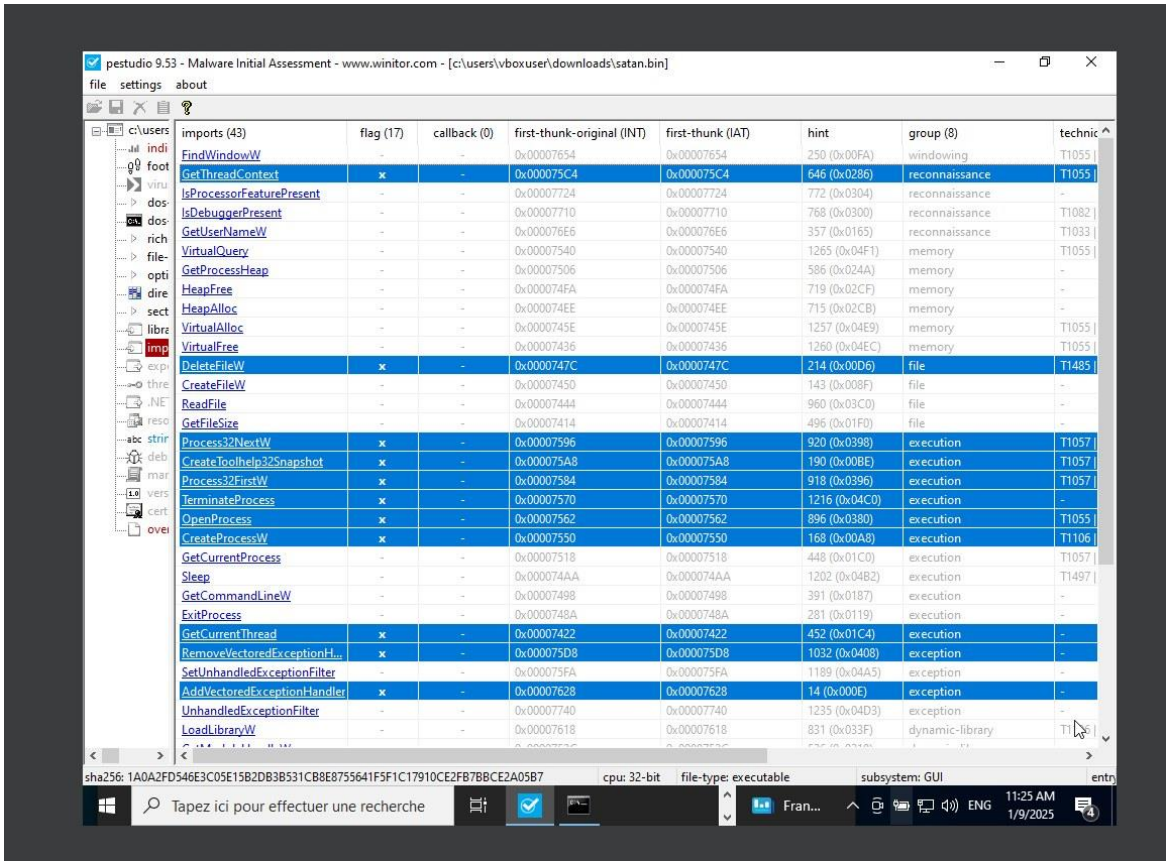
6. Les Imports — L'ADN du Malware

6.1 Qu'est-ce qu'une fonction importée ?

Un programme Windows ne réinvente pas la roue : il appelle des fonctions déjà présentes dans des bibliothèques système (DLL — Dynamic Link Library). La liste des imports est donc la liste des 'outils' que le programme va utiliser.

> **Import Address Table (IAT)**
> La table des imports (IAT) est une liste de toutes les fonctions externes que le programme appelle.
> Elle est chargée par Windows au démarrage du programme, avant même que le code s'exécute.
> En analysant cette table, on peut déduire CE QUE FAIT le programme sans l'exécuter.
> PE Studio affiche 43 imports pour satan.bin, dont 17 marqués comme suspects (flag).

6.2 Imports suspectes — Partie 1 : Reconnaissance et processus



▲PE Studio — Table des imports : reconnaissance, mémoire, processus, fichiers (colonnes MITRE ATT&CK visibles)

Catégorie : Reconnaissance (surligné en bleu)

Fonction importée	Description	Usage malveillant
IsDebuggerPresent	Vérifie si un débogueur est attaché	Anti-analyse : le malware se comporte différemment si analysé
IsProcessorFeaturePresent	Détecte les capacités du CPU	Reconnaissance système / détection VM
GetUserNameW	Récupère le nom de l'utilisateur courant	Identification de la victime
GetThreadContext	Accède au contexte d'un thread	Lecture des registres → injection de code

Anti-analyse avec IsDebuggerPresent

IsDebuggerPresent est LA technique classique d'évasion. Si un débogueur est détecté, le malware peut :

- Se terminer sans rien faire (pour ne pas être analysé).
- Chiffrer un mauvais contenu pour tromper l'analyste.
- Effacer ses traces.

Technique MITRE ATT&CK : T1497 — Virtualization/Sandbox Evasion.

Catégorie : Gestion des processus

Fonction importée	Description	Usage malveillant
CreateProcessW	Crée un nouveau processus	Lancer un processus enfant (ex: cmd.exe)
OpenProcess	Ouvre un processus existant	Accès à un processus victime pour injection
TerminateProcess	Termine un processus	Tuer les antivirus ou les outils de backup
Process32NextW / FirstW	Énumère tous les processus	Cartographie des processus actifs
CreateToolhelp32Snapshot	Snapshot des processus	Récupère la liste de tous les processus en cours

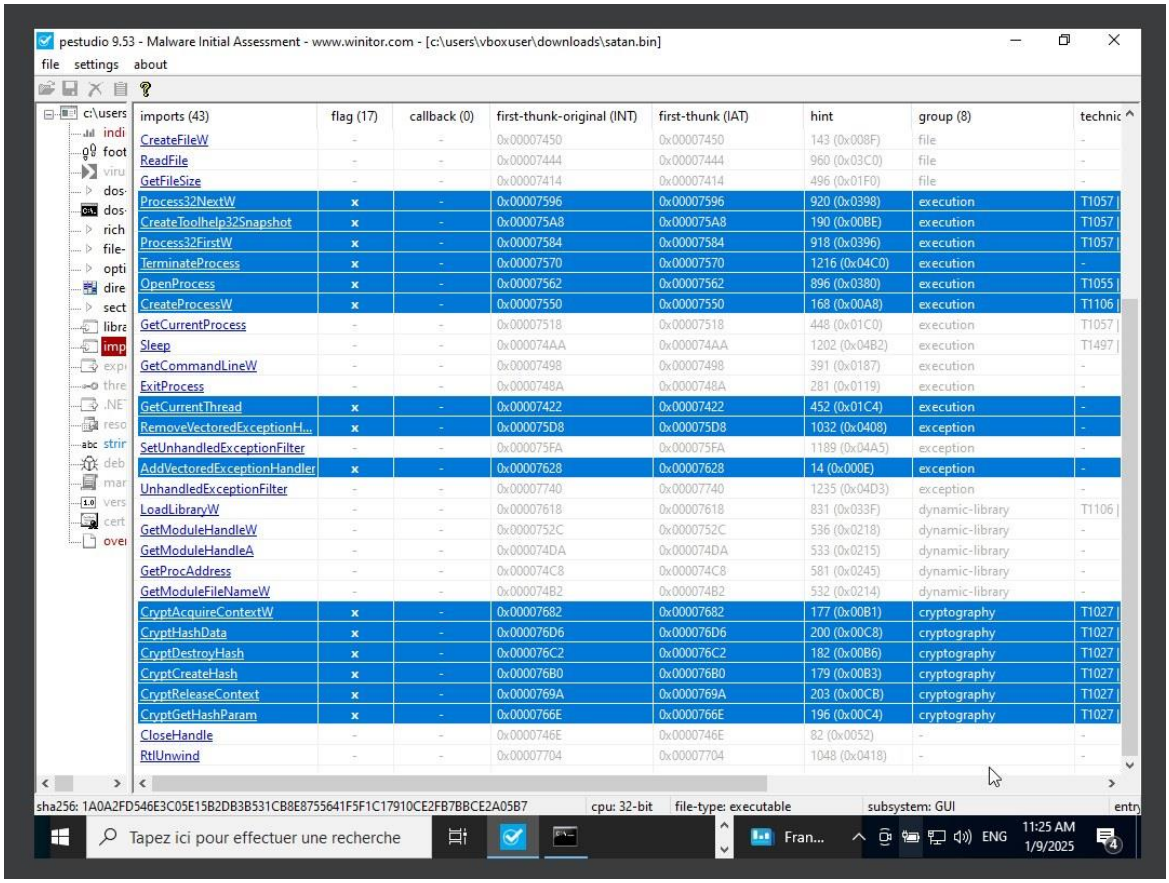
Catégorie : Gestion de la mémoire

- VirtualAlloc : alloue une zone mémoire exécutable → injection de shellcode.
- HeapAlloc / HeapFree : gestion du tas → stockage temporaire du payload en mémoire.
- VirtualFree : libère la mémoire → nettoyage des traces après injection.

Catégorie : Gestion des fichiers

- CreateFileW : crée ou ouvre un fichier → pour chiffrer les fichiers de la victime.
- DeleteFileW : supprime un fichier → efface les originaux après chiffrement. Technique T1485.
- ReadFile : lit le contenu → lit les fichiers avant de les chiffrer.
- GetFileSize : obtient la taille → pour allouer le bon buffer de chiffrement.

6.3 Imports suspectes — Partie 2 : Cryptographie (la clé du ransomware)



▲PE Studio — Imports cryptographiques (CryptAcquireContextW, CryptHashData, etc.) — tous marqués T1027

La section la plus révélatrice de l'analyse est la présence d'un groupe complet de fonctions cryptographiques Windows (CryptoAPI) :

Fonction cryptographique	Rôle	Ce que cela signifie
CryptAcquireContextW	Initialise le moteur cryptographique	Point de départ du chiffrement
CryptCreateHash	Crée un objet de hachage	Génère une clé à partir d'un mot de passe ou d'un sel
CryptHashData	Hache des données	Dérive la clé de chiffrement
CryptDestroyHash	Détruit l'objet de hachage	Nettoyage après génération de clé
CryptGetHashParam	Récupère la valeur du hash	Obtient la clé finale
CryptReleaseContext	Libère le contexte	Fin de l'opération cryptographique

Confirmation : c'est un ransomware

L'ensemble de ces fonctions forme un pipeline cryptographique complet :

1. CryptAcquireContextW → initialise le moteur de chiffrement Windows.
2. CryptCreateHash + CryptHashData + CryptGetHashParam → génère une clé de chiffrement.
3. (implicitement) Chiffrement des fichiers avec cette clé.
4. CryptDestroyHash + CryptReleaseContext → nettoyage.

Ce flux correspond EXACTEMENT au processus de chiffrement d'un ransomware.

Technique MITRE ATT&CK : T1027 — Obfuscated Files or Information

6.4 Récapitulatif des techniques MITRE ATT&CK identifiées

Le framework MITRE ATT&CK est un référentiel mondial qui classe les techniques offensives utilisées par les attaquants. En croisant nos découvertes avec ce référentiel :

https://attack.mitre.org/

Technique ID	Nom	Preuve dans satan.bin	Impact
T1055	Process Injection	OpenProcess, VirtualAlloc, GetThreadContext	Injection dans un processus légitime pour se dissimuler
T1485	Data Destruction	DeleteFileW flaggé	Supprime les originaux après chiffrement
T1497	Sandbox Evasion	IsDebuggerPresent, Sleep	Détecte l'environnement d'analyse
T1027	Obfuscated Files	CryptoAPI complète, entropie 7.99	Chiffre ses propres données et les fichiers victimes
T1106	Native API	CreateProcessW, LoadLibraryW	Appels directs aux API Windows sans abstraction
T1082	System Discovery	GetUserNameW, IsProcessorFeaturePresent	Reconnaissance de l'environnement victime

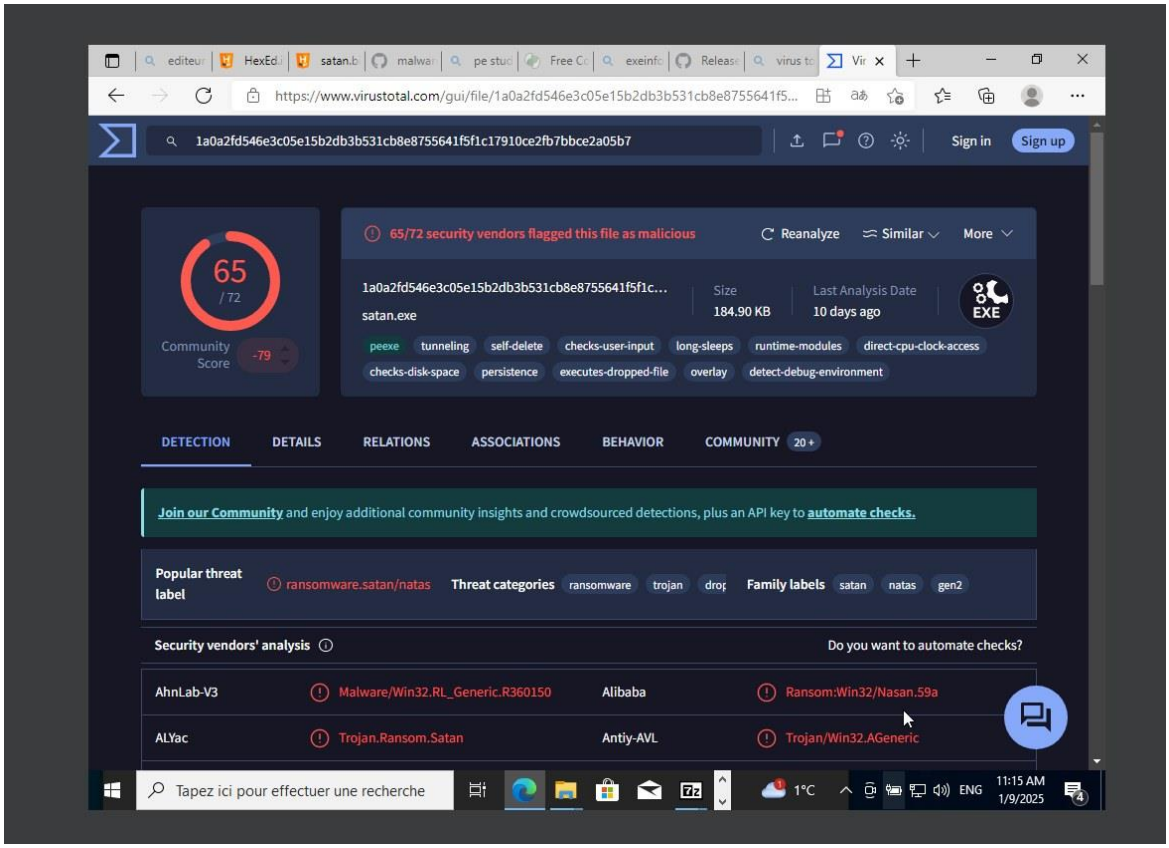
7. Verdict VirusTotal — Confirmation Multi-Moteurs

7.1 Qu'est-ce que VirusTotal ?

VirusTotal est une plateforme en ligne (propriété de Google depuis 2012) qui analyse un fichier ou une URL avec simultanément plus de 70 moteurs antivirus différents. C'est la référence mondiale pour la vérification rapide d'un fichier suspect.

> **Comment fonctionne VirusTotal ?**
> On soumet le fichier ou son hash. VirusTotal l'analyse avec une longue liste d'AV.
> Les résultats sont publics et partagés avec la communauté de cybersécurité.
> **IMPORTANT : ne jamais soumettre un fichier confidentiel à VirusTotal les fichiers soumis sont partagés avec les partenaires**

7.2 Résultats de la soumission



▲*VirusTotal — 65/72 moteurs détectent satan.bin comme malveillant (score communauté : -79)*

Le verdict est sans appel. Analysons en détail ce que VirusTotal nous apprend :

Indicateur	Valeur	Signification
Détections	65 / 72 moteurs	Taux de détection de 90.3% → menace confirmée et connue
Score communauté	-79	Très négatif : la communauté de chercheurs le classe comme dangereux
Threat label	ransomware.satan/natas	Famille clairement identifiée : Satan Ransomware
Catégories	ransomware, trojan, dropper	Triple rôle : chiffre, infiltre, installe d'autres composants
Family labels	satan, natas, gen2	'natas' = 'satan' à l'envers (humour des créateurs)
Date d'analyse	2025-01-09	Encore actif dans les bases de détection en 2025
Tags comportementaux	persistence, overlay, self-delete, tunneling	Cohérent avec notre analyse statique

7.3 Quelques classifications des antivirus

- AhnLab-V3 : Malware/Win32.RL_Generic.R360150
- ALYac : Trojan.Ransom.Satan
- Alibaba : Ransom:Win32/Nasan.59a
- ESET : Win32/Filecoder.Satan
- Kaspersky : Trojan-Ransom.Win32.Satan
- Bitdefender : Gen:Variant.Ransom.Satan

Conclusion VirusTotal

65 moteurs sur 72 détectent ce fichier comme malveillant.

La famille Satan Ransomware est connue depuis 2017. Ce ransomware a ciblé principalement des entreprises en proposant un 'Ransomware-as-a-Service' (RaaS) — des criminels pouvaient l'acheter et le déployer.

Le tag 'natas' confirme l'humour noir des créateurs ('satan' inversé).

8. Synthèse — Reconstitution du Scénario d'Attaque

8.1 Que fait satan.bin si on l'exécute ?

En croisant l'ensemble de nos analyses, nous pouvons reconstituer le comportement probable de satan.bin lors d'une exécution réelle (scénario théorique — nous ne l'avons pas exécuté) :

Étape	Technique	Imports / Indicateurs
1. Démarrage	Le programme se lance avec une interface GUI (fausse fenêtre)	Subsystem GUI
2. Anti-analyse	Vérifie si un débogueur est présent → adapte son comportement	IsDebuggerPresent, Sleep
3. Reconnaissance	Collecte le nom d'utilisateur, les infos système, les processus actifs	GetUserNameW, Process32NextW
4. Décompression	Déchiffre l'overlay (les 45% de données cachées) en mémoire	VirtualAlloc, entropie overlay 7.998
5. Injection	Injecte du code dans un processus Windows légitime (svchost.exe...)	OpenProcess, VirtualAlloc, T1055
6. Génération clé	Génère une clé de chiffrement unique pour cette victime	CryptAcquireContextW, CryptCreateHash
7. Chiffrement	Parcourt les disques, chiffre les fichiers (documents, photos, etc.)	CreateFileW, ReadFile, CryptoAPI
8. Nettoyage	Supprime les fichiers originaux, efface les traces	DeleteFileW, T1485
9. Persistance	Se configure pour redémarrer automatiquement	Tag 'persistence' VirusTotal
10. Rançon	Affiche un message demandant le paiement en Bitcoin	Windows GUI, dropper

8.2 Conclusion générale

Conclusion de l'analyse statique

satan.bin est un RANSOMWARE de la famille Satan (aussi connu sous Natas), apparu en 2017.

- Signature MZ + format PE Windows → exécutable déguisé.
- Overlay de 45% avec entropie 7.998 → charge utile chiffrée embarquée.
- Pipeline CryptoAPI complet → chiffrement des fichiers de la victime.
- IsDebuggerPresent → résistance à l'analyse.
- DeleteFileW flaggé → destruction des originaux après chiffrement.
- 65/72 antivirus le détectent → menace connue et documentée.

8.3 Bonnes pratiques de protection contre les ransomwares

- Effectuer des sauvegardes régulières (règle 3-2-1 : 3 copies, 2 supports, 1 hors site).
- Ne jamais ouvrir des pièces jointes ou exécutables provenant de sources inconnues.
- Maintenir son système et ses antivirus à jour (les signatures de satan.bin existent depuis 2017).
- Segmenter son réseau pour limiter la propagation en cas d'infection.
- Former les utilisateurs au phishing (vecteur d'infection principal des ransomwares).
- Activer la journalisation des événements système pour détecter les comportements anormaux.

—Fin—